APPSECWARRIOR

Penetration Testing Interview

Preparation Checklist

January 2026 · All Experience Levels

© 2026 AppSecWarrior

Beginner — **0 – 5 Years**

Fundamentals, OWASP Top 10, tooling, methodology, CTF & lab experience

Intermediate — **5 – 10 Years**

AD attacks, red team ops, cloud PT, AV evasion, client delivery skills, Conference meetup.

Expert — **10+ Years**

Exploit dev, 0-day research, stay updated with latest trends and info leadership, executive communication, Client escalation handling experience

© 2026 AppSecWarrior.org · All Rights Reserved

Things to Consider Before Any Pentest Interview

UNIVERSAL — ALL LEVELS

PREPARE
Know your role type
Internal PT vs consultancy vs red team vs bug bounty — each tests completely different skills

PREPARE
Prepare real examples
Hardest engagement, biggest mistake, most creative finding — one story per CV bullet

PREPARE
Legal & ethical clarity
Computer Misuse Act (UK) / CFAA (US), RoE, safe harbours, what to do with a live breach

PREPARE
Practice your one-liner
Lead every answer with one clear sentence then expand — never open with tool names

PREPARE
Research the company
Their client base, published CVEs, service lines, any breaches they've reported publicly

PREPARE
Know your certs cold
You will be quizzed on any cert you list — have technical depth behind every line

PREPARE
3 questions ready
Ask about their tooling, hardest engagement, team structure — shows genuine interest

PREPARE
Map CV to job spec
Each JD requirement → your matching story, lab proof, or cert. Don't leave gaps unmapped

GOLDEN RULE: Every answer needs a real example. 'I know how X works' is worth of Y 'I found Z on an engagement — here is XYZ what I did.'

© 2026 AppSecWarrior.org · All Rights Reserved

Interview Do's and Don'ts

ALL LEVELS

DO — say / do this	DON'T — avoid this
✓ Lead with a one-sentence summary, then go deeper on request	✗ Open with tool names — say what you achieved before mentioning the tool
✓ Admit gaps honestly: 'Haven't done X, but Y is very close'	✗ Bluff — experienced interviewers probe relentlessly until the gap surfaces
✓ Speak in business risk and impact, not just CVSS numbers	✗ Rate everything Critical — it signals poor calibration and weak judgement
✓ Quantify: '14 findings, 3 criticals, across 6-week engagement'	✗ Speak only in theory — ground every concept in a real or lab example
✓ Reference GitHub, CTF write-ups, blog, or personal home lab	✗ Volunteer client names, confidential details, or NDA-covered specifics
✓ Map to CVSS, OWASP, MITRE ATT&CK when the interviewer is technical	✗ Name-drop frameworks you cannot explain in detail if challenged
✓ Pause before answering hard questions — thinking looks confident	✗ Over-explain basics at senior level or under-deliver depth at junior level

© 2026 AppSecWarrior.org · All Rights Reserved

Beginner Checklist — Knowledge (0–5 Years)

BEGINNER · 0–5 YEARS

MUST — **OSI / TCP-IP model**
All 7 layers, protocols per layer, trace an HTTP request end-to-end

MUST — **SQL Injection — all types**
Error-based, union, blind boolean, time-based, OOB. Manual before sqlmap

MUST — **nmap fundamentals**
-sS -sV -sC -O -p- -T4. What each flag does. Stealth vs aggressive modes

MUST — **Windows / AD basics**
Domain, forest, DC, GPO. NTLM vs Kerberos high level. SMB, RDP, WinRM

GOOD — **Burp Suite core**
Proxy, Repeater, Intruder (sniper/cluster bomb), Decoder. Manual IDOR discovery

GOOD — **Password attacks**
hashcat/john modes, hash ID, rockyou/SecLists, rainbow tables vs salted hashes

MUST — **OWASP Top 10 (2025)**
All 10 by name (A01–A10), one real example + one mitigation per category

MUST — **XSS — Reflected/Stored/DOM**
How each fires, cookie theft impact, BeEF/XSSHunter. Severity vs impact distinction

MUST — **Linux CLI proficiency**
Permissions, pipes, grep/awk/sed, netstat, find, curl. Basic bash scripting

MUST — **CVE / CVSS basics**
Base/temporal/environmental scoring. Critical ≥9.0, High ≥7.0. Vector string

GOOD — **Metasploit basics**
msfconsole, search/use/set/exploit, handler, sessions, Meterpreter upgrade

GOOD — **File inclusion LFI/RFI**
Payload examples, log poisoning for RCE, path traversal ../../etc/passwd

© 2026 AppSecWarrior.org · All Rights Reserved

Beginner — Methodology & Interview Questions

BEGINNER · 0–5 YEARS

1·Plan & Scope | 2·Recon | 3·Scan & Enum | 4·Exploit | 5·Post-Exploit | 6·Report

Q What is the difference between a vuln and an exploit?

Vuln = weakness; exploit = code/technique that leverages it. Unpatched SMB is the vuln; EternalBlue is the exploit. Always define both and link them.

Q What is IDOR? Give a real example.

Insecure Direct Object Reference — changing account_id=123 to 124 to access another user's data. Fix: enforce server-side authorization on every object request.

Q How would you escalate privileges on Linux?

SUID binaries (GTFOBins), weak cron permissions, writable /etc/passwd, sudo -l misconfiguration, kernel exploits (uname -r), PATH hijacking in scripts.

Q Walk me through testing a web app from scratch.

Scope → passive recon → auth testing → injection points → access control → logic flaws → automated scan → report. Reference OWASP Testing Guide v4.

Q Difference between black box, grey box, white box?

Black = no knowledge; Grey = credentials/docs provided; White = full source + architecture. Each has different cost, depth, and risk coverage tradeoffs.

Q What do you do if you take down a production server?

Stop the test immediately. Call the client emergency contact per RoE. Document exactly what you ran. Assist with recovery. Transparency is non-negotiable.

© 2026 AppSecWarrior.org · All Rights Reserved

Intermediate Checklist — Knowledge (5–10 Years)

INTERMEDIATE · 5–10 YEARS

MUST

Active Directory (deep)

Kerberoasting, AS-REP, PtH/PtT, DCSync, Golden/Silver Ticket, BloodHound, ACL abuse

MUST

Custom payloads & AV evasion

Msfvenom, process injection (VirtualAlloc/WPM/CRT), AMSI bypass, shellcode loaders

MUST

C2 / red team tooling

Cobalt Strike/Havoc/Sliver: beaconing, malleable C2 profiles, BOFs, DNS C2

MUST

Network pivoting

SSH fwd, Chisel, ligolo-ng, socat, proxychains, double-pivot multi-hop

MUST

OSINT methodology

Shodan/Censys, crt.sh, LinkedIn enum, HaveIBeenPwned, Google dorking, ASN enum

GOOD

Mobile app basics

Android: jadx/apktool, cert pinning bypass (Frida). iOS: IPA analysis, plist inspection

MUST

Buffer overflow concepts

Stack layout, EIP/RIP control, NOP sled, pattern_create offset, bad chars, shellcode

MUST

Cloud penetration testing

AWS: IAM misconfig, SSRF→IMDS cred theft. Azure: AAD, App reg, Managed Identity

MUST

Advanced web attacks

OAuth/OIDC flaws, JWT (alg:none, RS→HS256), SSRF chains, XXE, deserialization

MUST

Windows privesc (advanced)

SeImpersonatePrivilege/Potato, DLL hijack, LSASS dump (Mimikatz), UAC bypass

MUST

Container / K8s security

Docker escape (privileged, socket abuse), K8s RBAC misconfig, secrets enumeration

GOOD

Advanced reporting

Narrative findings, exec risk summaries, CVSS justification, remediation roadmap

© 2026 AppSecWarrior.org · All Rights Reserved

Intermediate — Interview Questions

INTERMEDIATE · 5–10 YEARS

Q **Walk through a complex AD attack chain.**

Kerberoastable SPN → crack hash → lateral move → BloodHound path → DCSync. Be specific: which tool, exact finding, business impact. Name each stage.

Q **Explain DCSync and what it gives you.**

Mimikatz lsadump::dcsync /user:krbtgt needs Replication privileges. Dumps all NTLM hashes → Golden Ticket. krbtgt hash is the ultimate crown jewel.

Q **How do you steal AWS creds via IMDS?**

SSRF to 169.254.169.254/latest/meta-data/iam/security-credentials/<role> → temp keys. EC2-hosted server required. IMDSv2 needs token header first.

Q **How do you bypass AMSI?**

Reflection patching (AmsiScanBuffer), provider bypass, string obfuscation, PS v2 downgrade. Know 2–3 techniques and explain the mechanism behind each.

Q **Pass-the-Hash vs Pass-the-Ticket?**

PtH: NTLM hash in auth directly (NTLM protocol). PtT: Kerberos TGT/ST injected into memory (Kerberos). Different protocols = different mitigations.

Q **How do you write a finding a CISO acts on?**

Lead with business impact: breach cost, regulatory fine, downtime. Skip CVE numbers in exec summary. Quantify risk. Give a costed, prioritised remediation.

TIP: At intermediate level: demonstrate independence, real engagement examples, and the ability to explain impact to non-technical stakeholders.

© 2026 AppSecWarrior.org · All Rights Reserved

Expert Checklist — Knowledge (10+ Years)

EXPERT · 10+ YEARS

MUST — **Binary exploitation**
ROP chains (64-bit), tcache poison, UAF, double-free, kernel LPE, ret2libc, SROP

MUST — **Zero-day /reversers methodology**
AFL++/libFuzzer fuzzing, IDA Pro/Ghidra static analysis, variant analysis, BinDiff

MUST — **Threat modeling**
STRIDE, PASTA, Attack Trees. Threat-model an architecture from a diagram alone

MUST — **Programmed design & leadership**
Red team charter, scenario library, deconfliction, KPI dashboard, exec reporting

MUST — **OT / ICS / SCADA**
Purdue model, Modbus/DNP3, safety-first minimal-footprint, IT vs OT risk tolerance

BONUS — **Original CVE research**
Published CVEs, DEF CON/Black Hat talks, open-source tools authored — top differentiator

MUST — **Azure AD / hybrid attacks**
PRT theft, ADFS Golden SAML, cross-tenant, hybrid identity bridge, pass-through abuse

MUST — **Advanced OPSEC & evasion**
ETW patching, direct/indirect syscalls, ntdll unhooking, PPID spoof, sleep masking

MUST — **Secure architecture review**
Trust boundary failures, privesc paths, defence gaps — from design, no tools needed

MUST — **Regulatory frameworks**
PCI DSS req 11.3, ISO 27001, NIST CSF, DORA, UK CBEST/TBEST. What auditors need

MUST — **Hardware / firmware**
JTAG/UART debug, binwalk firmware extraction, secure boot bypass, side-channel

BONUS — **Community contribution**
Blog posts, mentoring, CTF challenges designed, academic papers, BSides talks

© 2026 AppSecWarrior.org · All Rights Reserved

Expert — Interview Questions

EXPERT · 10+ YEARS

Q **Design a red team programme from scratch.**

Charter + exec sponsorship → purple team baseline → scenario library (ransomware, nation-state) → deconfliction process → metrics dashboard → quarterly exec reporting.

Q **What are direct syscalls and why use them?**

Windows APIs → ntdll → kernel. EDRs hook ntdll. Direct syscalls call kernel stub directly bypassing the hook. Indirect: use ntdll stub address from a clean ntdll copy.

Q **Walk through AD CS ESC1 exploitation.**

Enroll in vulnerable cert template with SAN=DA UPN → get cert → PKINIT/UnPAC-the-hash → NTLM hash → PtH to Domain Admin. Certipy automates every step.

Q **Explain ETW patching. How do defenders detect?**

EtwEventWrite in ntdll overwritten with RET. Defenders: hash ntdll memory vs disk, canary ETW events, Sysmon Event 8 (CreateRemoteThread), TamperProtection alerts.

Q **Threat-model an internet-facing API.**

STRIDE per endpoint: spoofing (auth bypass), tampering (input validation), repudiation (audit log), info disclosure, DoS (rate limiting), EoP (IDOR, JWT alg confusion).

Q **Explain ADFS Golden SAML attack.**

Steal ADFS token signing key (ADFSDump) → forge SAML assertion for any user including Global Admin → authenticate to any SAML service — no password or MFA needed.

TIP: Expert interviews test architectural thinking and programme leadership — not just 'can you run Mimikatz'. Show you've made the industry better.

© 2026 AppSecWarrior.org · All Rights Reserved

Tools — What to Know at Each Level

ALL LEVELS

Tool	Category	Level	What to say	What to say in interview
nmap	Recon/Scan	Beginner+		-sS -sV -sC -O -p- -T4. Know what each does to the wire. Stealth vs aggressive. Script categories (vuln, auth).
Burp Suite	Web Testing	Beginner+		Proxy, Repeater, Intruder (sniper/cluster bomb), Decoder, Logger. Can you find IDOR manually without Scanner?
Metasploit	Exploitation	Beginner+		msfconsole: search/use/set/run, handler setup, sessions, Meterpreter upgrade. Know what the module does first.
sqlmap	SQLi	Beginner+		Always demo manual SQLi first. Tamper scripts for WAF bypass (space2comment, charunicodeescape). --level/--risk.
BloodHound	AD Enum	Intermediate		SharpHound ingestors, attack paths, ACL edges, Kerberoastable users, shortest path to DA, AS-REP nodes.
Mimikatz	Cred Theft	Intermediate		sekurlsa::logonpasswords, lsadump::dcsync /user:krbtgt, kerberos::golden. Why LSASS? Explain PPL protection.
Cobalt Strike	C2/Red Team	Intermediate		Beacon types, malleable C2 profiles, BOFs, OPSEC-safe commands. Know Havoc/Sliver as open-source alternatives.
Impacket	AD/SMB	Intermediate		secretsdump, psexec, wmiexec, GetUserSPNs (Kerberoast), GetNPUsers (AS-REP). Read the source — interviewers do.
ligolo-ng	Pivoting	Intermediate		Reverse tunnel + SOCKS5. Agent on target, proxy on attacker. Route config. Supports multi-hop pivots cleanly.
Frida	Dynamic Anal.	Intermediate		Hook Obj-C/Java methods at runtime, SSL pinning bypass (iOS/Android), frida-trace, custom JS scripts.
IDA Pro/Ghidra	Rev Eng	Expert		Decompiler, xref analysis, function rename/retype, identifying vuln patterns, patch diffing with BinDiff/Diaphora.
AFL++/libFuzz	Fuzzing	Expert		Coverage-guided fuzzing for 0-day research. Corpus generation, crash deduplication, minimisation, harness writing.

© 2026 AppSecWarrior .org· All Rights Reserved

Certifications — What Each One Signals

ALL LEVELS

Beginner — **eJPT / PNPT**

Practical lab-based. PNPT includes real report writing. Both highly regarded in

Mid–Senior — **OSEP**

Advanced: AD attacks, AV evasion, custom C2 usage. Signals red team

Senior — **CRTE / CRTO II**

Advanced AD attacks, cross-forest, Kerberos delegation abuse. Altered

Expert — **OSED**

Windows exploit dev. ROP chains, custom shellcode, DEP/ASLR bypass. Rare and highly valued. Signals binary exploitation research capability.

Mid — **OSCP**

Industry standard. 24hr exam + report. No Metasploit rule (mostly). Know:

Mid — **CRTO**

Cobalt Strike red team ops. Practical simulated AD environment. Highly

Senior — **OSWE**

Web app expert. Source code review, authentication bypass, RCE chains.

Expert — **GXPN / GREM**

SANS/GIAC expert tier. Very expensive; signals employer investment. GXPN: expert network exploitation. GREM: malware reverse engineering.

Senior — **BSCP**

Advanced penetration testing credential. Signals deep expertise in security assessment and employer commitment.

RULE: Certs are conversation starters. Be ready to be grilled on any cert you claim. Depth behind the cert wins every time.

© 2026 AppSecWarrior.org · All Rights Reserved

Same Topic — Expected Depth at Each Level

HOW DEEP TO GO

Topic	Beginner 0–5	Intermediate 5–10	Expert 10+
SQL Injection	Know types, test with ' or 1=1--, explain impact (auth bypass, data theft), mention sqlmap after manual demo.	Union-based vs blind (boolean/time), WAF bypass (encoding, tampering), second-order SQLi, sqlmap tamper scripts.	Custom blind SQLi script from scratch, SQLi in stored procedures + NoSQL ($where), chain to RCE via INTO OUTFILE or xp_cmdshell.
Windows Privesc	AlwaysInstallElevated, unquoted service paths, weak service permissions, whoami /priv, winPEAS usage.	SeImpersonatePrivilege → Potato attacks, DLL hijacking, LSASS dump (Mimikatz/comsvcs.dll), UAC bypass (fodhelper), token manipulation.	Kernel exploit dev (win32k, CLFS), DCOM/COM object abuse, custom loader + sleep masking, ETW patching, ACL-based DACL persistence.
Active Directory	Know what AD is, DC/domain/forest/GPO, basic enumeration (net user, net group), what Kerberos does at a high level.	Kerberoasting, BloodHound paths, DCSync, PtH/PtT, Golden/Silver Ticket, ACL abuse (GenericWrite, WriteDACL, ForceChangePassword).	Azure AD hybrid bridge, ADFS Golden SAML, cross-forest trust, PRT theft, Diamond Ticket, AD CS ESC1–ESC8 abuse chains.
Reporting	Title, description, steps to reproduce, evidence screenshot, severity rating, one-line recommendation.	Narrative-driven findings, CVSS vector string, attack chain diagram, re-test results, exec summary, client debrief.	Bespoke CISO/Board decks, regulatory mapping (PCI DSS, DORA), maturity model benchmark, programme-level risk posture.

© 2026 AppSecWarrior.org · All Rights Reserved

Mindset & Soft Skills — Often the Deciding Factor

ALL LEVELS

Ethics & Legal

Know Computer Misuse Act (UK) / CFAA (US). Never test without written authorisation. Understand 'good faith' boundaries in detail.

Communication

Explain SQLi to a developer without jargon. Write clear, concise emails. Deliver board-level risk presentations without slides full of CVEs.

Learning Velocity

Active learning: TryHackMe, HackTheBox, CTFs, blog, GitHub. Can name 3 specific things learned in the last 30 days and what you did with them.

Curiosity

Ask 'why does this work?' not just 'how do I run this?'. Goes off-script in labs to explore unexpected findings. Reads patch notes and advisory detail.

Integrity

Would stop a test and call the emergency contact if a live breach is discovered in progress. Never exaggerates finding severity to look more impressive.

Ownership

Takes full responsibility for report quality and accuracy. Follows up on retests. At senior level: accountable for the entire programme's output.

Resilience

Handles client pushback professionally. Stays focused when a test hits a dead end. Can explain why zero findings is a valid and defensible result.

Mentoring mindset

Explains concepts to juniors clearly, reviews their reports constructively, lifts team quality. Interviewers ask 'have you ever trained someone?' always.

© 2026 AppSecWarrior.org · All Rights Reserved

The 5-Sentence Formula for Any Technical Answer

CHEAT SHEET

1	**What it is**	One sentence defining the concept or vulnerability class.
2	**How it works**	One sentence on the mechanism — cause and effect, clearly.
3	**Real example**	'I found this during a test when...' or 'A real-world case is...'
4	**Impact**	What can an attacker achieve? What are the business consequences?
5	**Mitigation**	What fixes it? Be specific — parameterised queries, not 'input validation'.

EXAMPLE: **SQL Injection**

(1) SQLi lets attackers inject SQL commands into application queries. (2) Unsanitised user input is concatenated into a SQL string and executed by the database. (3) I found one in a login form — the error message leaked the DB structure. (4) Full database dump, potential authentication bypass, PII exposure. (5) Fix: parameterised queries / prepared statements — never string concatenation.

© 2026 AppSecWarrior.org · All Rights Reserved

MITRE ATT&CK & CWE Mapping — Say These in Senior Interviews

AppSecWarrior

FRAMEWORKS

ID	Technique	Where it appears	What to say in interview
T1203	Exploit for client execution	JBIG2/iMessage parser exploitation — the initial RCE vector (FORCEDENTRY example)	Say: 'Initial execution maps to T1203 — exploit for client execution via a malicious media attachment auto-processed by the OS.'
T1404	Exploit OS vulnerability	Kernel privilege escalation after sandbox escape — chaining to root	Say: 'Privilege escalation to root maps to T1404 — kernel vuln chained after the logic bug escape.'
T1190	Exploit public-facing app	Web app attacks: SQLi, SSRF, XXE, deserialization on external services	Say: 'Initial access on external targets maps to T1190 — exploiting public-facing application vulnerabilities.'
T1078	Valid accounts	Credential attacks: PtH, PtT, Kerberoasting, LSASS dump → lateral movement	Say: 'Lateral movement using stolen credentials maps to T1078 — valid accounts, covering both PtH and Kerberos ticket abuse.'
T1548	Abuse elevation control	UAC bypass, Potato attacks (SeImpersonatePrivilege), sudo misconfigurations	Say: 'Local privilege escalation via UAC bypass or token abuse maps to T1548 — abuse of elevation control mechanisms.'
T1630	Indicator removal	Pegasus/malware self-cleanup; log deletion; CASCADEFAIL forensic artefact	Say: 'Defence evasion via cleanup maps to T1630. CASCADEFAIL shows even sophisticated cleanup leaves artefacts.'

Key CWEs to cite: CWE-190: Integer overflow | CWE-122: Heap buffer OOB | CWE-269: Improper privilege mgmt | CWE-693: Protection mechanism failure | CWE-502: Deserialization

TIP: Cite MITRE IDs naturally mid-answer, not as a list at the end. 'That lateral movement maps to T1078' lands better than reciting IDs separately.

© 2026 AppSecWarrior.org · All Rights Reserved

Final Cheat Sheet — Read This the Morning of Your Interview

AppSecWarrior

QUICK REFERENCE

The 3 questions every pentest interview is really asking:

1. Can you actually do the job? (technical depth + real examples from real or lab work)
2. Will you stay out of jail and keep us safe? (ethics, RoE, legal awareness, disclosure)
3. Can clients and colleagues work with you? (communication, reporting quality, attitude)

Prove these — Beginner

- Correct fundamentals
- Lab / CTF experience
- Genuine curiosity
- Basic report structure
- Ethical awareness
- Active learning habit

Prove these — Intermediate

- Real engagement examples
- AD attack chain depth
- Custom tooling ability
- Client communication
- Cloud & evasion skills
- Scoping & RoE knowledge

Prove these — Expert

- Original research / CVEs
- Architectural thinking
- Programme leadership
- Executive communication
- Community contribution
- Mentoring track record

FINAL RULE: Every answer needs a real example. 'I know how X works' is worth HALF of 'I found X on an engagement — here is what I did and why it mattered.'

© 2026 AppSecWarrior.org · All Rights Reserved

AppSecWarrior

Good luck In Your Next Interview

Now go break things — ethically.

- Lead with a one-liner, then go deeper only when asked
- Every claim needs a real example — lab work counts
- Admit gaps honestly — 'I haven't done X yet but Y is close'
- Ask them one good question — it signals genuine interest
- Match depth to seniority — don't over or under-deliver

© 2026 AppSecWarrior · All Rights Reserved · Pentest Interview Preparation Checklist

© 2026 AppSecWarrior.org · All Rights Reserved